Kế HOẠCH PHÁT TRIỂN CAI_LO

Agent pentest tự động hóa end-to-end — điều khiển Kali VM từ Windows, tự suy luận chuỗi tấn công

---

Phạm vi sử dụng: lab nội bộ, CTF, và pentest các hệ thống được yêu cầu / ủy quyền. • Ngày: 02/11/2026

1. Mục tiêu

Nâng CAI_LO từ trạng thái gọi tool theo từng lượt thành một agent tự chủ kiểu "HackerAI": nhận 1 mục tiêu, tự lập kế hoạch, tự chạy nhiều bước, tự điều chỉnh và báo cáo — với bộ não (LLM + agent) chạy trên Windows còn tay chân thực thi nằm trên máy ảo Kali.

2. Hiện trạng — đã có ~70% nền

Các mảnh cốt lõi đã tồn tại trong mã nguồn:

Thành phần	Vai trò	Trạng thái
LLM reasoning	Bộ não — Ollama / Gemini	✅ Đã có
Thực thi host (executor.py)	PTY/subprocess, Docker, SSH, CTF	✅ Đã có
~30 agent chuyên trách	web_pentester, red_teamer, bug_bounter, reporter…	✅ Đã có
Orchestration agent	Chia mục tiêu lớn → chuỗi bước	✅ Đã có
API + WebUI dashboard	FastAPI, SSE streaming, quan sát real-time	✅ Đã có
Vòng lặp tự chủ (autonomy loop)	Tự lặp nhiều bước không cần người bấm	⚠️ Còn thiếu
Trí nhớ chiến dịch (state store)	Nhớ host/port/cred để nối bước	⚠️ Còn thiếu
Scope guard + audit log	Chặn lệnh ngoài phạm vi, ghi log	⚠️ Còn thiếu

3. HackerAI hoạt động thế nào (vòng lặp agentic)

Bản chất là một vòng lặp quấn quanh LLM, lặp tự động nhiều chục bước:

- PERCEIVE — đọc trạng thái mục tiêu (output nmap, response HTTP, lỗi tool…)
- PLAN — LLM suy luận bước tiếp theo (recon → enum → exploit → …)
- ACT — gọi tool: chạy lệnh trên host thực thi
- OBSERVE — bắt kết quả, parse thành dữ kiện
- REFLECT — thành công? thất bại? đổi hướng → quay lại PERCEIVE

Điểm mấu chốt: cái phân biệt "trợ lý trả lời" với "HackerAI tự chạy" không phải model mạnh hơn, mà là vòng lặp tự động có trí nhớ và biết tự sửa sai.

4. Kiến trúc Windows → Kali VM

Dự án đã có sẵn backend SSH: khi đặt SSH_USER + SSH_HOST, bộ điều phối lệnh tự động route MỌI lệnh tool sang máy từ xa (Kali). Bộ não vẫn chạy trên Windows.

Cấu hình thử (.env):

```
SSH_USER="kali"
SSH_HOST="192.168.x.x"   # IP máy ảo Kali
# Bỏ SSH_PASS trên Windows — dùng SSH key thay vì sshpass
```

3 điểm yếu cần gia cố (trên Windows):

- sshpass không có trên Windows → bắt buộc dùng SSH key (nhánh ssh thuần).
- Chưa xử lý host-key → cần -o StrictHostKeyChecking=accept-new (tránh treo lần kết nối đầu).
- _run_ssh chạy one-shot mỗi lệnh → tool tương tác (msfconsole, sqlmap prompt) chưa chạy tốt, cần nâng session bền / PTY.

5. Nguyên tắc an toàn (bắt buộc)

Công cụ chỉ phục vụ lab/CTF/pentest được ủy quyền. Ba thứ sau là hạ tầng kỹ thuật (giúp debug & tái hiện), không phải lớp trang trí:

- Scope guard: allowlist CIDR; lệnh nhắm mục tiêu ngoài phạm vi bị chặn TRƯỚC khi chạy — cứu bạn khỏi chính agent khi nó “lạc” target.
- Audit log append-only: ai/agent, lệnh, target, thời gian, exit code — cần để debug vòng lặp tự chủ.
- Human-in-the-loop: hành động phá hủy (ghi/xóa/C2/exfil) phải qua cổng xác nhận.

6. Lộ trình 4 giai đoạn

Giai đoạn	Nội dung	"Xong" nghĩa là
GĐ 0 — Windows→Kali	Cấu hình .env SSH; gia cố _run_ssh (key auth, host-key, document)	Gõ lệnh ở Windows → chạy thật trên Kali
GĐ 1 — Scope + audit	enforce_scope() chặn ngoài allowlist; log append-only	Agent không thể lạc IP; mọi lệnh có log
GĐ 2 — Autonomy loop ⭐	plan→act→observe→reflect→replan; budget/max_turns; checkpoint	Giao 1 mục tiêu CTF → agent tự chạy tới flag
GĐ 3 — Trí nhớ	SQLite lưu host/port/service/cred/finding; nạp lại context	Agent nối chuỗi tấn công, không quên

7. Ước lượng thời gian

Mốc	Effort (ngày công)	Lịch (bán thời gian)
GĐ 0 — Windows→Kali	1–2 ngày	
GĐ 1 — Scope + audit	0.5–1 ngày	
GĐ 2 — Autonomy loop	2–4 ngày	
GĐ 3 — Trí nhớ	1–2 ngày	
MVP chạy được (GĐ 0–2)	~4–6 ngày công	~1–2 tuần
Bản ổn định dùng thật	+1–2 tuần nữa	~3–4 tuần tổng

Rủi ro làm chậm: (1) tool tương tác qua SSH cần session bền — phần dễ ngốn thời gian nhất; (2) chất lượng model local khi reasoning chuỗi dài — có thể dùng Gemini cho khâu planning.

8. Việc bắt đầu ngay

- Bắt đầu GĐ 0 (Windows→Kali) — cho kết quả ngay và là nền cho mọi thứ sau.
- Tiếp GĐ 1 (scope + audit) trước khi bật tự chủ — để vòng lặp tự chạy an toàn trên lab/CTF thật.
- Sau đó GĐ 2 (autonomy loop) — trái tim của "tự suy nghĩ như HackerAI".